SBOM / CVE / Patch

Çıktı: Vulnerability Decision | EP 09 + EP 10 + EP 11

Ad Soyad: **Grup:** **Tarih: 01.11.2026**

[B] Makineye özgü SBOM, PLC modeli ve firmware sürümü doğrulanmadı [K1]. [V] Föyün örnek zafiyet kaydı gerçek makine bulgusu değildir. Karar: etkilenme belirsiz; yama uygulanmaz, kanıt toplanır.

[D] Kaynakta doğrulanan | [B] Bilinmiyor | [V] Varsayım | [Ö] Öneri | [Ç] Analitik çıkarım

Verilen zafiyet kaydı - yalnız eğitim senaryosu [F1]

[V] Bileşen: Component X (PLC firmware kütüphanesi); sürüm: 2.4; kayıt: CVE-XXXX-XXXX (yer tutucu, gerçek CVE değil); önem: Critical / CVSS 9.8; yama: mevcut varsayılıyor. CVSS sürümü/vektörü ve yama paketi verilmemiştir. Bu bilgiler Karmetal'e atanmaz. CVSS ciddiyet puanıdır; tek başına makinenin riskini göstermez [K9].

Görev 1 - bu CVE gerçekten etkiliyor mu? Üç koşul

Kontrol	Sonuç	Eksik kanıt / karar
Bileşen var mı?	[B] Bilinmiyor	Modelle eşleşen SBOM / bağımlılık listesi yok; Component X varlığı kanıtlanmadı.
Sürüm etkileniyor mu?	[B] Bilinmiyor	Gerçek sürüm ve üretici güvenlik duyurusu yok; 2.4 yalnız senaryo verisi.
Açık ulaşılabilir mi?	[B] Bilinmiyor	Arayüz, yetki ve tetiklenme koşulları doğrulanmadı; internet erişimi tek ölçüt değil.

Görev 2-5 - karar akışı

2. Üretimi hemen durdurur musunuz?

[Ö] Yalnız 9.8 puanı/yer tutucu nedeniyle otomatik duruş kararı verilmez. Bu, üretime devam onayı değildir. Emniyet kaybı, yetkisiz değişiklik veya beklenmeyen hareket belirtisinde yetkili işletme ekibi kontrollü güvenli duruşa geçer; kayıtları korur ve servis yolunu sınırlar.

3. Yamayı doğrudan mı, önce test ederek mi uygularsınız? Nerede?

[Ö] Önce üretimden ayrılmış, aynı donanım/sürümü temsil eden yetkili test düzeneğinde. Üreticinin paket kaynağı ve bütünlüğü, uyumluluk, yedek/geri dönüş ve regresyon sonuçları doğrulanır. Temsilî düzenek yoksa başarı varsayılmaz; üretime körlemesine yüklenmez. Bu projede yama testi/kurulumu yapılmadı [K5].

4. Yama emniyet validasyonunu etkiler mi? Nasıl anlaşılır?

[B] Değişiklik kapsamı bilinmiyor. [Ö] Sürüm notları, devre ve bağımlılık incelemesiyle kapak/şerit duruşu, tepki süresi, reset ve yük tutma etkisi belirlenir. Yetkili uzman etkilenen fonksiyonları yeniden doğrular; salt üretim çalışıyor gözlemi yeterli değildir [K5].

5. Yama mümkün değilse telafi edici önlem nedir?

[Ö] Varsa gereksiz servis yolunu kapat; gerekli erişimi süreli, kişisel ve en az yetkili yap; servis cihazını denetle ve konfigürasyon değişikliklerini izle. Süreli risk kararı, sorumlu ve gözden geçirme tarihi kaydedilsin. Önlemler açığı gidermez; emniyet gösterilemiyorsa duruş sürdürülür.

Vulnerability Decision - sonuç ve kanıt paketi

VD-05 / durum: AÇIK - etkilenme belirsiz; doğrulanmış zafiyet yok. [Ö] EP 09: üretici, bileşen adı/sürümü, tanımlayıcı ve bağımlılık kanıtını kaydet; bilinmeyeni açık yaz [K8]. EP 10: gerçek duyuru ile bileşen/sürüm/erişim eşlemesi. EP 11: yama, geri dönüş ve emniyet test kayıtları. Sorumlu önerisi: işletmenin bakım + emniyet yetkilisi; öğrenci belge takibini yapar. Yeni kanıt/duyuru gelince veya sonraki laboratuvar öncesi yeniden incele.

SBOM: yazılım malzeme listesi. Yukarıdaki tablo tam SBOM değildir. Ağ taraması ve gerçek sisteme müdahale yapılmadı.

[F1] Dersin Lab Föyleri PDF dosyası, s. 6 (yerel) | [K1] Karmetal ürün sayfası | [K5] NIST SP 800-82 Rev.3 | [K8] SBOM 2026 rehberi | [K9] FIRST CVSS rehberi | Bağlantılar tıklanabilir; kaynak/kanıt kaydı: docs/KAYNAKLAR.md. Erişim: 01.11.2026.